MADO JBot

Техническое задание и план модернизации
Telegram HR-бота в полноценную HR-платформу

Telegram Bot • Telegram Mini App • Backend API • Admin Panel • PostgreSQL • 2FA

Цель: перенести проект на VPS, обеспечить стабильный запуск и построить единую систему подбора, оценки и найма сотрудников MADO.

Репозиторий: https://github.com/dilshikk/mado_jbot

Версия 1.0 • 14 октября 2026

1. Резюме

Рекомендуется развивать репозиторий как MADO HR Platform — систему подбора персонала, доступную из Telegram и через защищённую веб-панель. Telegram остаётся точкой входа и каналом уведомлений; Mini App становится основным интерфейсом для HR, менеджеров и руководителей.

В репозитории обнаружены Python/aiogram 3, сценарии кандидатов и интервью, модели SQLAlchemy, Alembic, планировщик, интеграция Google Sheets и AI-модули. Отдельная завершённая Mini App/frontend-структура в дереве файлов не обнаружена. Это означает, что интерфейс и связующий API нужно разработать, а не просто включить настройкой.

Документ описывает целевую архитектуру и план работ. Перечисленные функции — требования к разработке, а не утверждение, что они уже реализованы.

2. Анализ текущего репозитория

Область	Что найдено	Вывод
Запуск	main.py, polling, startup/shutdown, повтор сетевых ошибок.	Сохранить polling для первого этапа; настроить systemd и health checks.
Telegram	aiogram 3.29.1, handlers, keyboards, middleware, FSM.	Сохранить сценарии и провести регрессионные тесты.
База данных	SQLAlchemy async; SQLite по умолчанию; поддержка PostgreSQL; Alembic.	Для production использовать PostgreSQL и единый процесс миграций.
HR	Анкеты, вакансии, интервью, административные действия, метро/локации.	Составить карту бизнес-процессов и согласовать pipeline.
AI	AI-модули и необязательный OpenAI API.	AI только помогает HR; решение о найме принимает человек.
Интеграции	Google Sheets и планировщик уведомлений.	Определить, Sheets — экспорт, интеграция или источник данных.
Mini App/API	Завершённый frontend и отдельный API не обнаружены в дереве.	Разработать frontend/API; браузер не подключать напрямую к БД.
Деплой	requirements.txt и .env.example; Dockerfile/Compose в корне не обнаружены.	Добавить инструкции, конфигурацию запуска, backup/restore.
Тесты	Есть каталог tests с тестами регистрации, БД, AI, middleware и др.	Запустить существующие тесты и добавить security/integration tests.

Это обзор структуры и выбранных файлов. Он не заменяет запуск кода, проверку всех веток, зависимостей, секретов и фактического состояния VPS.

3. Цели и границы

- Надёжно запустить существующего Telegram-бота на VPS и обеспечить автоматический перезапуск.
- Открывать Mini App одной кнопкой в чате бота.
- Создать единый HR-интерфейс для кандидатов, вакансий, интервью и этапов найма.
- Добавить веб-админ-панель с разграничением доступа по ролям и филиалам.
- Внедрить 2FA для административных аккаунтов и критичных операций.
- Добавить историю действий, уведомления, отчёты, экспорт, резервное копирование и мониторинг.

Не входит в первый релиз

- Автоматическое принятие решений о найме AI-моделью.
- Микросервисная архитектура/Kubernetes без измеримой необходимости.
- Интеграции с внешними HR/ERP без согласованного API.

4. Роли и права

Роль	Разрешения
Super Admin / Owner	Все филиалы, настройки, роли, администраторы, аудит и интеграции.
HR Admin	Кандидаты, вакансии, интервью, офферы и отчёты в разрешённом периметре.
HR Recruiter	Кандидаты, контакты, заметки, этапы, расписание интервью и задачи.
Branch Manager	Данные назначенного филиала, оценки интервью и запросы на найм.
Interviewer	Только назначенные интервью и оценочные формы.
Viewer / Auditor	Чтение разрешённых данных и журналов без изменения записей.
Candidate	Только собственная анкета, документы и доступные статусы.

Backend должен проверять права на каждом запросе. Скрытая кнопка в интерфейсе не является защитой. Роль и филиал берутся из серверной сессии, а не из параметров браузера.

5. Telegram → Mini App

- Бот показывает кнопку «Открыть HR-панель», ведущую на HTTPS-домен Mini App.
- Frontend передаёт Telegram initData backend; backend проверяет подпись и свежесть данных по официальному алгоритму Telegram.
- Не доверять initDataUnsafe как доказательству личности; не принимать Telegram ID, присланный клиентом, без серверной проверки.
- После проверки backend проверяет статус пользователя, роли, филиалы и требование 2FA.
- Создаётся ограниченная по времени серверная сессия; выход отзывает сессию.
- Интерфейс адаптируется к мобильному Telegram, Telegram Desktop и обычному браузеру в рамках разрешённой политики.

Нельзя помещать BOT_TOKEN, ключи API и секреты в JavaScript frontend. Нужны HTTPS, ограниченные CORS/origins, защита сессий, безопасные ошибки и rate limiting.

6. Функции Mini App

6.1. Главная

- KPI: новые кандидаты, назначенные интервью, ожидающие решения, открытые вакансии, просроченные задачи.
- Последние события, фильтры по филиалу/вакансии/ответственному/периоду.
- Быстрые действия: создать вакансию, открыть кандидата, назначить интервью, добавить заметку.

6.2. Кандидаты / ATS

- Список с поиском, сортировкой, фильтрами, пагинацией и сохранёнными представлениями.
- Карточка: контакты, анкета, желаемая должность, филиал, доступность, опыт, документы и история.
- Настраиваемый pipeline: Новый → На проверке → Связаться → Интервью → Оценка/пробная смена (если применяется) → Предложение → Принят / Отказ / Резерв.
- История каждого перехода с автором, временем, причиной и старым/новым статусом.
- Назначение HR, филиала, вакансии, приоритета, следующего контакта и напоминания.
- Поиск дублей по нормализованному телефону/Telegram ID с подтверждением возможного совпадения.
- Контролируемые причины отказа; CSV/XLSX экспорт только с разрешением и записью в аудит.

6.3. Вакансии

- Создание, редактирование, архивирование и публикация вакансий.
- Поля: должность, филиал, количество мест, описание, требования, график, язык, ответственный и срок закрытия.
- Шаблоны по должностям: waiter, runner, cashier, barista, cook, cleaner, hostess и другие.
- Статусы Draft, Open, Paused, Filled, Archived; история изменений и источники откликов.

6.4. Интервью

- Календарь с часовым поясом Asia/Tashkent, интервьюером, филиалом, форматом и статусом.
- Проверка конфликтов времени, уведомления о переносе и отмене.
- Шаблоны вопросов и критерии оценки по должности/языку.
- Результат: следующий этап, резерв, отказ или повторное интервью.
- AI может составлять сводку и предлагать вопросы, но не отклоняет кандидатов самостоятельно.

6.5. Администрирование

- Управление пользователями, ролями, филиалами и назначениями.
- Справочники: должности, источники, статусы, причины отказа, шаблоны сообщений.
- Настройки уведомлений, 2FA, сессий, сроков хранения и интеграций.
- Журнал аудита с фильтрами по пользователю, действию, объекту и времени.
- Статусы сервисов, БД и последней успешной резервной копии.

7. Двухфакторная аутентификация и безопасность

Для администраторов рекомендуется TOTP через приложение-аутентификатор и одноразовые резервные коды. Telegram-вход связывает пользователя с Telegram-аккаунтом, но не заменяет независимый второй фактор для привилегированных операций.

Процесс подключения

- После Telegram-авторизации backend требует включить 2FA для административной роли.
- Пользователь сканирует QR-код; backend проверяет TOTP и только после подтверждения активирует 2FA.
- Резервные коды показываются один раз, хранятся только в виде хешей и помечаются использованными после применения.
- Сброс/отключение 2FA требует повторной проверки личности, полномочий и записи в аудит.

Обязательные меры

- RBAC и принцип минимальных привилегий; изоляция филиалов на уровне каждого API-объекта.
- Rate limiting, задержки и блокировка перебора кодов, защита от повторного использования.
- Короткоживущие сессии, отзыв refresh-сессий, выход со всех устройств.
- Секреты вне репозитория; TOTP-секреты хранить зашифрованными; резервные коды и пароли — только в виде стойких хешей.
- Защита от SQL injection, XSS, CSRF, IDOR, SSRF и вредоносных файлов.
- Аудит смены ролей, экспорта, доступа к чувствительным данным, 2FA и критичных настроек.
- Ротация токена через BotFather при подозрении на компрометацию.

2FA не заменяет серверную проверку прав, защиту сессий, аудит и тестирование негативных сценариев.

8. Техническая архитектура

Компонент	Рекомендация	Назначение
Telegram bot	Python + aiogram 3	Команды, уведомления и запуск Mini App.
Backend API	FastAPI + Pydantic	REST API, бизнес-логика, авторизация и RBAC.
Frontend	React + TypeScript + Vite + Telegram WebApp SDK	Mini App и адаптивная админ-панель.
Database	PostgreSQL	Единый источник данных production.
ORM / migrations	SQLAlchemy 2.x + Alembic	Модели и контролируемые миграции.
Фоновые задачи	APScheduler на первом этапе; очередь/Redis по необходимости	Напоминания, рассылки, повторы.
Reverse proxy	Nginx + TLS	HTTPS, маршрутизация, заголовки и лимиты.
Управление процессами	systemd для текущего подхода либо Docker Compose после аудита	Автозапуск, рестарт и управляемые релизы.
Мониторинг	journald, ротация, health endpoints	Диагностика и обнаружение ошибок.

Не следует одновременно управлять одним процессом через systemd и Docker без чёткой схемы. Сначала обследовать VPS и выбрать единый способ запуска.

9. Целевая структура проекта

mado_jbot/
├── bot/ — Telegram handlers, keyboards, middleware
├── api/ — FastAPI routers, dependencies, schemas
├── domain/ — бизнес-правила HR и pipeline
├── db/ — SQLAlchemy models, sessions, repositories
├── services/ — уведомления, Google Sheets, AI, файлы
├── security/ — initData, 2FA, RBAC, sessions
├── frontend/ — React + TypeScript Mini App
├── alembic/ — миграции
├── tests/ — unit, integration, security tests
├── deploy/ — systemd, nginx, backup/restore
├── docs/ — архитектура, API, runbook
├── .env.example
└── main.py

Не менять структуру механически. Сначала проверить импорты, циклические зависимости, модели и текущие миграции, затем выделять модули небольшими проверяемыми изменениями.

10. Основные сущности БД

Сущность	Назначение
users	Telegram ID, профиль, статус, язык, last_seen.
roles / user_roles	Роли и разрешения пользователей.
branches / user_branch_access	Филиалы и доступ пользователей к филиалам.
candidates	Контакты, анкета, источник, согласие, текущий этап.
candidate_documents	Метаданные файлов, checksum, тип и разрешения.
vacancies	Должность, филиал, число мест, статус и сроки.
applications	Связь кандидат–вакансия и этап pipeline.
interviews / interview_scores	Расписание, интервьюеры, оценки и комментарии.
pipeline_events	История переходов и причин.
tasks / notifications	Задачи, дедлайны, попытки и статус уведомления.
auth_sessions / user_2fa	Сессии, отзыв, зашифрованный TOTP secret.
recovery_codes	Хеши резервных кодов и использование.
audit_logs	Кто, когда, над каким объектом и что сделал.
consents / retention	Основание обработки, сроки хранения, удаление/анонимизация.

Использовать внешние ключи, уникальные ограничения, индексы и транзакции. Хранить timestamps в UTC, отображать время Asia/Tashkent. Собирать только необходимые персональные данные.

11. Базовый API

Метод / маршрут	Назначение
POST /api/v1/auth/telegram	Проверка Telegram initData и создание сессии.
POST /api/v1/auth/2fa/verify	Проверка TOTP для входа/критичного действия.
POST /api/v1/auth/2fa/enroll	Начало настройки 2FA.
POST /api/v1/auth/logout	Отзыв текущей сессии.
GET /api/v1/me	Профиль, роли, филиалы, состояние 2FA.
GET/POST /api/v1/candidates	Список и создание кандидатов.
GET/PATCH /api/v1/candidates/{id}	Просмотр и изменение разрешённых полей.
POST /api/v1/candidates/{id}/stage	Переход pipeline с проверкой и аудитом.
GET/POST /api/v1/vacancies	Список и создание вакансий.
GET/POST /api/v1/interviews	Расписание интервью.
POST /api/v1/interviews/{id}/score	Оценка интервью.
GET /api/v1/dashboard/summary	KPI только по разрешённым данным.
GET /api/v1/audit	Журнал для уполномоченных ролей.
GET /health/live и /health/ready	Проверка процесса и готовности критических зависимостей.

Для всех изменяющих запросов обязательны серверная авторизация, проверка схемы и объекта, транзакция, аудит и тесты на межфилиальный доступ. Добавить пагинацию, единый формат ошибок и версионирование API.

12. Перенос на VPS

Шаг 1. Обследование

- Проверить ОС, ресурсы, свободное место, порты, домены и правила firewall.
- Инвентаризировать systemd, PM2, Nginx, Docker, PostgreSQL/SQLite и логи.
- Убедиться, что тот же Telegram-бот не запущен вторым процессом: два polling-процесса могут конфликтовать.
- Зафиксировать текущие пути, права, переменные окружения и процедуру отката.

Шаг 2. Backup

- Зафиксировать commit и текущую конфигурацию без публикации секретов.
- Сохранить базу и пользовательские файлы; проверить читаемость копии.
- SQLite backup выполнять согласованным способом; PostgreSQL — pg_dump с защищённым файлом.
- Сохранить Nginx/systemd-конфигурацию и инструкцию отката.

Шаг 3. Установка (пример для Ubuntu/Debian)

Только после проверки ОС и существующих сервисов. Не переустанавливать уже работающие компоненты без обследования.

```
sudo apt update
sudo apt install -y git python3 python3-venv python3-pip build-essential nginx certbot python3-certbot-nginx postgresql postgresql-contrib
```

Если PostgreSQL уже обслуживает другие проекты, не переустанавливать его и не менять глобальные параметры без плана. Создать отдельную БД и пользователя с минимальными правами.

```
cd /opt
sudo git clone https://github.com/dilshikk/mado_jbot.git
sudo chown -R $USER:$USER /opt/mado_jbot
cd /opt/mado_jbot
python3 -m venv .venv
source .venv/bin/activate
pip install --upgrade pip wheel
pip install -r requirements.txt
```

Перед production проверить совместимость Python и зависимостей, закрепить проверенный набор пакетов и выполнить аудит уязвимостей.

Шаг 4. Конфигурация

- Создать отдельный .env с минимальными правами доступа.
- Задать BOT_TOKEN, ADMIN_IDS, ADMIN_CHAT_ID, DATABASE_URL, LOG_PATH, LOG_LEVEL и необходимые интеграции.
- Использовать отдельную БД и пользователя; не открывать порт БД в интернет.
- Не коммитить .env, credentials.json, дампы и ключи; проверить git status и историю репозитория.
- Настроить домен и HTTPS до подключения Mini App.

Шаг 5. Тесты и миграции

```
source .venv/bin/activate
pytest -q
alembic upgrade head
python main.py
```

Порядок команд зависит от фактической конфигурации БД и Alembic. Если init_db и Alembic оба управляют схемой, нужно выбрать единый механизм, чтобы не возникли конфликты. Не применять миграции к production без backup и проверки.

Шаг 6. systemd

Пример шаблона; заменить пути, пользователя и зависимости под реальный VPS. Не запускать приложение от root.

```
[Unit]
Description=MADO HR Telegram Bot
After=network-online.target postgresql.service
Wants=network-online.target

[Service]
Type=simple
User=madohr
WorkingDirectory=/opt/mado_jbot
EnvironmentFile=/etc/mado-jbot/mado-jbot.env
ExecStart=/opt/mado_jbot/.venv/bin/python /opt/mado_jbot/main.py
Restart=on-failure
RestartSec=5
TimeoutStopSec=30
NoNewPrivileges=true
PrivateTmp=true

[Install]
WantedBy=multi-user.target
```

После настройки: перечитать конфигурацию systemd, включить автозапуск, проверить status и journalctl. Секреты в unit-файл не вписывать.

Шаг 7. Mini App / HTTPS

- Собрать React frontend в статические файлы и обслуживать через Nginx либо отдельный frontend-контейнер.
- Проксировать /api/ на backend; не открывать БД наружу.
- Выпустить TLS-сертификат и настроить автоматическое продление.
- Настроить домен Web App в BotFather и проверить iOS, Android, Desktop.
- Проверить CSP, CORS, лимиты тела запросов и отсутствие секретов в frontend bundle.

Шаг 8. Мониторинг

- Проверять статус процессов, рестарты и последнее успешное выполнение.
- Ротировать логи; не писать токены, полные анкеты и коды 2FA.
- Проверять доступность БД, API и последней резервной копии.
- Уведомлять администратора о падениях и неудачном backup.
- Еженедельно тестировать восстановление backup в тестовой среде.

13. Конфиденциальность

- Собирать только необходимые для найма данные и показывать понятное уведомление об обработке.
- Согласовать правовое основание, тексты согласия, срок хранения и удаление с ответственным лицом.
- Не передавать контакты и документы в Google Sheets/AI без отдельного согласования.
- Файлы хранить вне публичной директории; проверять тип, размер, имя и доступ.
- Экспорт и массовые рассылки требуют отдельного разрешения и аудита.
- Резервные копии шифровать, ограничивать доступ и задавать срок хранения.
- AI использовать как вспомогательный инструмент с человеческой проверкой; не ранжировать по чувствительным характеристикам.

14. Идеи для сильного продукта

Идея	Польза	Приоритет
Канбан найма	Видны этапы, блокеры и ответственные.	MVP
Единая карточка	Анкета, контакты, интервью и история вместе.	MVP
Шаблоны по должностям	Вопросы и критерии для официанта, повара, бариста и др.	MVP
SLA и просрочки	Подсветка кандидатов без ответа и долгих вакансий.	MVP
QR-ссылка на вакансию	Отклик через QR в филиале.	Этап 2
Реферальная программа	Учитывать рекомендации сотрудников и результат.	Этап 2
Библиотека интервью	Единые критерии и обучение интервьюеров.	Этап 2
Аналитика источников	Конверсия, срок закрытия вакансии, причины отказа.	Этап 2
AI-помощник HR	Сводка анкеты и предложения вопросов; человек принимает решение.	Этап 2
Мультиязычные сообщения	Русский, узбекский, английский, турецкий.	Этап 2
Security Center	Входы, изменения ролей, экспорт, 2FA и подозрительные действия.	MVP
Импорт CSV/XLSX	Предварительный просмотр, валидация и поиск дублей.	Этап 2
Резервный режим	Критические уведомления через Telegram при недоступности Mini App.	MVP

15. Критерии приёмки

Область	Критерий
Запуск	После перезагрузки VPS сервис запускается автоматически; сбой не приводит к тихому падению.
Telegram	Сценарии кандидата работают; Mini App открывается с кнопки.
Авторизация	Поддельная/изменённая/просроченная initData отклоняется.
2FA	Работают подключение, TOTP, резервные коды, защита повторного использования и аудит сброса.
RBAC	Нельзя получить данные чужого филиала подменой ID/параметров.
ATS	Статусы, интервью, ответственные и история переходов сохраняются.
База	Миграции применяются к чистой БД и тестовой копии; backup восстанавливается.
API	Валидация, пагинация, лимиты, безопасные ошибки, отсутствие утечек секретов.
Файлы	Неподдерживаемые и слишком большие файлы блокируются; нет публичного доступа.
Мониторинг	Ошибки видны в логах; критические проблемы вызывают уведомление.
Регрессия	Существующие тесты проходят; добавлены интеграционные и security-тесты.

Перед production не должно оставаться неисправленных критических/высоких уязвимостей. Нагрузочные цели и RTO/RPO нужно определить после оценки ресурсов VPS и ожидаемого количества пользователей.

16. План реализации

Этап	Работы	Результат
0. Аудит	VPS, зависимости, тесты, схема БД, секреты, процессы.	План запуска и отката.
1. Стабильный бот	Окружение, БД, миграции, systemd, backup, smoke tests.	Рабочий бот на VPS.
2. API	FastAPI, Telegram initData, сессии, RBAC, health checks.	Защищённый backend.
3. Mini App MVP	Главная, кандидаты, вакансии, карточки, pipeline, интервью.	HR работает из Telegram.
4. Админ и 2FA	Роли, филиалы, TOTP, резервные коды, аудит, отзыв сессий.	Защищённое администрирование.
5. Автоматизация	Уведомления, дедлайны, шаблоны, экспорт и отчёты.	Меньше ручной работы.
6. Аналитика/AI	Сводки с human review, SLA и источники откликов.	Измеримый HR-процесс.
7. Hardening	Security review, тест восстановления, нагрузка, runbook.	Production-ready релиз.

17. Проверки на реальном VPS

- Точная ОС, Python, ресурсы и права на каталоги.
- Список работающих сервисов; отсутствие второго polling-процесса того же бота.
- Фактические пути проекта, виртуального окружения, логов и credentials.
- Доступность Telegram API с VPS.
- Фактически используемая БД, наличие данных и план миграции.
- Порты, Nginx и домены; не перезаписывать конфигурации других приложений.
- HTTPS и домен Mini App.
- Секреты в Git history; ротация токенов при необходимости.
- Полный тестовый сценарий от отклика до решения о найме на staging.

18. Итоговое решение

Сохранить текущий бот и HR-логику, постепенно выделить API и построить Mini App как отдельный frontend. PostgreSQL должен стать основным хранилищем production. Доступ администратора — через проверенную Telegram-авторизацию, серверную проверку прав и 2FA для привилегированных ролей.

Правильный порядок: резервная копия и обследование VPS → стабильный бот → API → Mini App → админ-панель и 2FA → автоматизация и аналитика. Не начинать с большого рефакторинга поверх работающего сервера без инвентаризации и плана отката.

Документация:
GitHub: https://github.com/dilshikk/mado_jbot
Telegram Mini Apps: https://core.telegram.org/bots/webapps
Telegram Bot API: https://core.telegram.org/bots/api
PostgreSQL: https://www.postgresql.org/docs/
Alembic: https://alembic.sqlalchemy.org/